Domanda 1

Risposta corretta

Punteggio ottenuto 1,00 su 1,00

Contrassegna domanda

Mi voglio ritirare da questo appello

○ Vero

● Falso ✓

La risposta corretta è 'Falso'.

Domanda 2

Parzialmente corretta

Punteggio ottenuto 4,50 su 6,00

Contrassegna domanda

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo,
selezionando una risposta sbagliata si ha un punteggio negativo,
non selezionare una risposta dà 0,
la somma dei punteggi può essere negativa,
almeno due risposte sono vere e almeno due sono false,
selezionare più di *n-2* risposte come vere sarà considerato attacco a forza bruta)

- ☑ a. Derivare una chiave crittografica direttamente da una password, senza usare una KDF moderna con salt e parametri appropriati, ad esempio il numero di iterazioni, facilita attacchi a dizionario o forza bruta sulla password. ✓
- ☐ b. Se la verifica del tag AEAD fallisce, il destinatario non dovrebbe usare il plaintext eventualmente ottenuto durante la decifratura, perché non ha garanzia che ciphertext o dati autenticati siano integri.
- ☐ c. L’uso di una chiave casuale di lunghezza adeguata rende irrilevante la scelta del modo operativo e del vettore di inizializzazione negli algoritmi a blocchi.
- ☑ d. La verifica di un certificato X.509 richiede di costruire una catena di certificazione fino a una root CA fidata, verificando le firme dei certificati, la loro validità e lo scopo per cui il certificato viene usato. ✓
- ☐ e. In una ciphersuite TLS basata su AES-GCM, l’algoritmo GCM fornisce solo confidenzialità; l’autenticazione dei dati deve essere calcolata con un MAC separato, ad esempio HMAC-SHA256.
- ☐ f. Un HMAC calcolato con una chiave condivisa consente a una terza parte di attribuire il messaggio a uno specifico partecipante, perché solo chi conosce la chiave può generarlo.
- ☐ g. Per firmare con RSA è sufficiente applicare direttamente l’operazione RSA al digest del messaggio; il padding usato nello schema di firma incide solo sul formato della firma e non sulle sue proprietà di sicurezza.
- ☐ h. La ciphersuite TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 indica che il pre-master secret viene cifrato con la chiave pubblica RSA del server; quindi, se in futuro venisse compromessa la chiave privata RSA, si potrebbero decifrare le sessioni precedenti.
- ☑ i. In ECDSA, la scelta di una curva ritenuta sicura non è sufficiente se l’implementazione riutilizza o rende prevedibile il nonce usato nelle firme: in tali casi la chiave privata può essere compromessa. ✓

Le risposte corrette sono:
Se la verifica del tag AEAD fallisce, il destinatario non dovrebbe usare il plaintext eventualmente ottenuto durante la decifratura, perché non ha garanzia che ciphertext o dati autenticati siano integri.,

La verifica di un certificato X.509 richiede di costruire una catena di certificazione fino a una root CA fidata, verificando le firme dei certificati, la loro validità e lo scopo per cui il certificato viene usato.,

In ECDSA, la scelta di una curva ritenuta sicura non è sufficiente se l’implementazione riutilizza o rende prevedibile il nonce usato nelle firme: in tali casi la chiave privata può essere compromessa.,

Derivare una chiave crittografica direttamente da una password, senza usare una KDF moderna con salt e parametri appropriati, ad esempio il numero di iterazioni, facilita attacchi a dizionario o forza bruta sulla password.

Domanda 3

Risposta errata

Punteggio ottenuto 0,00 su 6,00

Contrassegna domanda

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo,
selezionando una risposta sbagliata si ha un punteggio negativo,
non selezionare una risposta dà 0,
la somma dei punteggi può essere negativa,
almeno due risposte sono vere e almeno due sono false,
selezionare più di *n-2* risposte come vere sarà considerato attacco a forza bruta)

- ☑ a. Proteggere con STARTTLS il collegamento SMTP tra due nodi è sufficiente a garantire la riservatezza end-to-end del messaggio fino al destinatario finale. ✗
- ☐ b. Un proxy che termina HTTPS può leggere il contenuto HTTP e reinoltrarlo su una nuova connessione protetta; se venisse usato S-HTTP, sul proxy non si potrebbe leggere il payload HTTP protetto.
- ☐ c. La sicurezza di messaggio protegge le informazioni rendendo alcune proprietà di sicurezza auto-contenute nel messaggio, invece di proteggerle solo durante il transito su un canale sicuro.
- ☑ d. S/MIME è pensato per proteggere messaggi MIME e può fornire integrità, autenticazione, non ripudio e, opzionalmente, riservatezza. ✓
- ☐ e. In S/MIME, allegare al messaggio il certificato del mittente permette al destinatario di ottenere la chiave pubblica da usare nella verifica perché un certificato allegato nella stessa struttura CMS è di per sé fidato.
- ☑ f. Se Alice vuole inviare a Bob una busta cifrata, può cifrare la chiave simmetrica usata per cifrare il contenuto con la propria chiave pubblica, permettendo a Bob di recuperare il contenuto. ✗
- ☐ g. L’uso di S/MIME consente di bloccare phishing, Business Email Compromise e allegati malevoli, perché l’autenticazione e l’integrità del messaggio garantiscono l’identità del mittente e l’assenza di contenuti malevoli o ingannevoli.
- ☑ h. In un messaggio S/MIME clear-signed, il contenuto resta leggibile anche da client che non gestiscono S/MIME; se però un MTA o un attaccante modifica il contenuto durante il trasporto, un destinatario che esegue la verifica S/MIME non ha modo di rilevare l’alterazione. ✗
- ☐ i. MIME estende il formato RFC822 per aggiungere funzionalità di sicurezza ai dati binari tramite contenuti multipart.

Le risposte corrette sono:
La sicurezza di messaggio protegge le informazioni rendendo alcune proprietà di sicurezza auto-contenute nel messaggio, invece di proteggerle solo durante il transito su un canale sicuro.,

S/MIME è pensato per proteggere messaggi MIME e può fornire integrità, autenticazione, non ripudio e, opzionalmente, riservatezza.,

Un proxy che termina HTTPS può leggere il contenuto HTTP e reinoltrarlo su una nuova connessione protetta; se venisse usato S-HTTP, sul proxy non si potrebbe leggere il payload HTTP protetto.

Domanda 4

Parzialmente corretta

Punteggio ottenuto 3,50 su 6,00

Contrassegna domanda

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo,
selezionando una risposta sbagliata si ha un punteggio negativo,
non selezionare una risposta dà 0,
la somma dei punteggi può essere negativa,
almeno due risposte sono vere e almeno due sono false,
selezionare più di *n-2* risposte come vere sarà considerato attacco a forza bruta)

- ☐ a. EAP definisce soltanto il modo per trasportare dati di autenticazione; non si può quindi parlare di livello di sicurezza di EAP.
- ☑ b. In eduroam, l’infrastruttura visitata può inoltrare la richiesta verso l’Authentication Server dell’istituzione di appartenenza, mentre le credenziali dell’utente possono essere protette da un canale virtuale sicuro end-to-end verso tale server, ad esempio tramite TTLS. ✓
- ☑ c. Un port scan basato solo sulle porte aperte consente di identificare con certezza il servizio applicativo in esecuzione, perché il numero di porta determina il protocollo effettivamente usato dal server. ✗
- ☐ d. Nel modello NIST, il Verifier coincide con la Relying Party che concede l’accesso alla risorsa; quindi, in un’architettura AAA/RADIUS, il NAS deve verificare direttamente le credenziali dell’utente prima di autorizzare l’accesso alla rete.
- ☑ e. In RADIUS, il NAS raccoglie la richiesta di accesso dell’utente e la inoltra al server RADIUS, che restituisce una risposta come Access-Accept, Access-Reject o Access-Challenge; in funzione del metodo di autenticazione, il NAS può dover inoltrare all’utente una richiesta di ulteriori informazioni. ✓
- ☑ f. Le funzioni AAA non si limitano alla verifica dell’identità dell’utente, ma includono anche decisioni sui diritti di accesso e registrazione dell’uso delle risorse. ✓
- ☐ g. L’uso di RADIUS rende automaticamente multifattore l’autenticazione dell’utente, perché il server può rispondere con Access-Challenge e richiedere ulteriori informazioni.
- ☐ h. Rispetto a PAP, CHAP rende non riutilizzabile una risposta osservata sul canale e impedisce attacchi a dizionario quando il segreto condiviso è debole.
- ☐ i. RADIUS può essere considerato un esempio di zero-knowledge proof per l’autenticazione degli utenti, perché il NAS delega la verifica delle credenziali al server di autenticazione.

Le risposte corrette sono:
EAP definisce soltanto il modo per trasportare dati di autenticazione; non si può quindi parlare di livello di sicurezza di EAP.,

Le funzioni AAA non si limitano alla verifica dell’identità dell’utente, ma includono anche decisioni sui diritti di accesso e registrazione dell’uso delle risorse.,

In RADIUS, il NAS raccoglie la richiesta di accesso dell’utente e la inoltra al server RADIUS, che restituisce una risposta come Access-Accept, Access-Reject o Access-Challenge; in funzione del metodo di autenticazione, il NAS può dover inoltrare all’utente una richiesta di ulteriori informazioni.,

In eduroam, l’infrastruttura visitata può inoltrare la richiesta verso l’Authentication Server dell’istituzione di appartenenza, mentre le credenziali dell’utente possono essere protette da un canale virtuale sicuro end-to-end verso tale server, ad esempio tramite TTLS.

Domanda 5

Parzialmente corretta

Punteggio ottenuto 2,40 su 6,00

Contrassegna domanda

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo,
selezionando una risposta sbagliata si ha un punteggio negativo,
non selezionare una risposta dà 0,
la somma dei punteggi può essere negativa,
almeno due risposte sono vere e almeno due sono false,
selezionare più di *n-2* risposte come vere sarà considerato attacco a forza bruta)

- ☑ a. Accessi, divulgazioni o modifiche non autorizzate di dati personali possono costituire un data breach; il titolare deve notificarlo al Garante quando la violazione può comportare un rischio per i diritti e le libertà degli interessati. ✓
- ☐ b. L’acquisto di un prodotto certificato elimina la necessità di ulteriori valutazioni di sicurezza, perché la certificazione è sufficiente a garantire che il prodotto soddisfi i requisiti specifici dell’organizzazione che lo adotta.
- ☐ c. Il Cyber Solidarity Act mira a rafforzare la capacità collettiva europea di prevenzione, rilevamento e risposta agli incidenti informatici su larga scala.
- ☑ d. Un attacco che porta all’esfiltrazione di dati personali può avere conseguenze rilevanti per il GDPR anche se non produce indisponibilità del servizio o danni diretti all’infrastruttura. ✓
- ☐ e. DORA introduce obblighi specifici per la resilienza digitale degli operatori essenziali e importanti, mentre NIS2 è la normativa specifica per il settore finanziario.
- ☐ f. Il Cyber Resilience Act stabilisce requisiti per la resilienza di infrastrutture critiche e sistemi di rilevanza nazionale.
- ☑ g. Il principio di minimizzazione del GDPR non richiede di usare il minor numero possibile di strumenti informatici, ma di limitare i dati trattati rispetto agli scopi dichiarati. ✓
- ☐ h. Un’azienda certificata ISO 27001 dimostra di aver adottato i controlli tecnici più efficaci tra quelli disponibili per mitigare i rischi dell’organizzazione.
- ☑ i. Una firma digitale basata su crittografia asimmetrica ha pieno valore giuridico perché consente di verificare integrità, autenticità e non ripudio del documento firmato. ✗

Le risposte corrette sono:
Un attacco che porta all’esfiltrazione di dati personali può avere conseguenze rilevanti per il GDPR anche se non produce indisponibilità del servizio o danni diretti all’infrastruttura.,

Il Cyber Solidarity Act mira a rafforzare la capacità collettiva europea di prevenzione, rilevamento e risposta agli incidenti informatici su larga scala.,

Il principio di minimizzazione del GDPR non richiede di usare il minor numero possibile di strumenti informatici, ma di limitare i dati trattati rispetto agli scopi dichiarati.,

Accessi, divulgazioni o modifiche non autorizzate di dati personali possono costituire un data breach; il titolare deve notificarlo al Garante quando la violazione può comportare un rischio per i diritti e le libertà degli interessati.

Domanda 6

Parzialmente corretta

Punteggio ottenuto 3,50 su 6,00

Contrassegna domanda

Scegli le affermazioni vere dalla lista:

(selezionando una risposta esatta si ha un punteggio positivo,
selezionando una risposta sbagliata si ha un punteggio negativo,
non selezionare una risposta dà 0,
la somma dei punteggi può essere negativa,
almeno due risposte sono vere e almeno due sono false,
selezionare più di *n-2* risposte come vere sarà considerato attacco a forza bruta)

- ☐ a. Gli standard e le normative internazionali analizzati a lezione richiedono di adottare la misura più efficace tra quelle disponibili; la gestione del rischio residuo è ammessa solo quando non esistono mitigazioni applicabili.
- ☑ b. La strategia “difficult ones later” suggerisce di rimandare i sistemi complessi o legacy perché sono normalmente meno critici e quindi meno rilevanti nella valutazione del rischio. ✗
- ☐ c. Se una vulnerabilità non può essere corretta subito, il rischio associato deve essere necessariamente accettato fino alla disponibilità della patch, perché non è possibile migliorare il livello di protezione.
- ☐ d. Quando una patch corregge una vulnerabilità ad alta severità, la priorità corretta è distribuirla subito su tutti i sistemi affetti, perché il rischio operativo legato all’installazione della patch è sempre inferiore rispetto alla riduzione della window of exposure.
- ☐ e. La presenza di un firewall o di un IPS davanti a un servizio vulnerabile consente di rimandare l’applicazione delle patch senza impatti sul rischio, perché impedisce comunque lo sfruttamento della vulnerabilità.
- ☑ f. Durante un vulnerability assessment, information gathering e scanning consentono di identificare host, servizi e versioni software, così da collegarli a vulnerabilità note. ✓
- ☑ g. Durante la window of exposure, controlli temporanei come modifiche di configurazione, regole IDS/IPS o riduzione dell’esposizione possono diminuire il rischio, anche se la vulnerabilità non è ancora stata corretta. ✓
- ☐ h. Un punteggio CVSS elevato non implica necessariamente che una vulnerabilità debba essere corretta prima di vulnerabilità con CVSS più basso, perché la priorità dipende anche da esposizione del sistema, sfruttabilità attesa e impatto sul contesto specifico.
- ☑ i. Il Risk Management Framework del NIST è un processo iterativo che include framing, assessment, response/mitigation e monitoring. ✓

Le risposte corrette sono:
Il Risk Management Framework del NIST è un processo iterativo che include framing, assessment, response/mitigation e monitoring.,

Durante un vulnerability assessment, information gathering e scanning consentono di identificare host, servizi e versioni software, così da collegarli a vulnerabilità note.,

Un punteggio CVSS elevato non implica necessariamente che una vulnerabilità debba essere corretta prima di vulnerabilità con CVSS più basso, perché la priorità dipende anche da esposizione del sistema, sfruttabilità attesa e impatto sul contesto specifico.,

Durante la window of exposure, controlli temporanei come modifiche di configurazione, regole IDS/IPS o riduzione dell’esposizione possono diminuire il rischio, anche se la vulnerabilità non è ancora stata corretta.